

Practice Set: Layer-Wise Attacks and Firewall Security

1. A university's examination server sends encrypted question papers to an authorized faculty member. An attacker performs the following actions:
 - (i) Observes the encrypted traffic and determines when question papers are being transmitted and their approximate size.
 - (ii) Intercepts a valid authorization-update message, modifies the list of authorized users, and forwards the modified message to the server.
 - (iii) Captures a previously valid authorization message and retransmits it later to obtain unauthorized access.
 - (iv) Sends a large number of requests to the server so that legitimate faculty members cannot access the system.For each of the four attacks, identify the type of security attack and the primary security service that is being compromised. Justify your answers.
2. Consider an online examination system that handles student registration, login, answer submission, and storage of examination records. For each of the following security requirements:
 - (i) Only authorized students should be allowed to access the examination system.
 - (ii) Answers submitted by students must not be altered during transmission.
 - (iii) A student should not be able to deny having submitted an answer after the examination.
 - (iv) Examination records must not be accessible to unauthorized users.
 - (v) The examination system must remain accessible to legitimate students throughout the examination.Identify the appropriate security service required for each requirement and explain. Explain why encryption alone cannot satisfy all the above security requirements.
3. A switched LAN uses a CAM table with a maximum capacity of 1024 MAC address entries. An attacker connected to one port begins sending Ethernet frames with randomly spoofed source MAC addresses at a high rate.
 - (a) Explain what happens to the switch's forwarding behavior once its CAM table becomes full. (b) Name one practical countermeasure that can be configured on the switch to mitigate this attack.
4. A computer with the IP address 192.168.1.100/24 tries to ping 192.168.1.200. An ARP request will be sent out first. What are the values of the following fields in the ARP message: (1) sender's MAC, (2) sender's IP, (3) target MAC, and (4) target IP?

5. A server S1 has IP address 192 . 168 . 1 . 10 and MAC address AA : AA : AA : AA : AA : AA . A backup server S2 is configured to take over the same IP address if S1 fails. When S1 fails, S2 takes over 192 . 168 . 1 . 10 and has MAC address BB : BB : BB : BB : BB : BB . However, several hosts on the LAN still have the following ARP entry: 192 . 168 . 1 . 10 → AA : AA : AA : AA : AA : AA .

(a) What type of ARP message should S2 send immediately after taking over the IP address, and what should be the Sender IP, Sender MAC, Target IP, and Target MAC fields in that message? (b) Explain what happens if S2 does not send this message.

6. In an MITM attack, the attacker M tries to intercept the communication between A and B that are on the same LAN. Please describe what M needs to do, so it can modify the packets from A to B.
7. (a) What is the primary goal of a DHCP starvation attack? (b) Why does using many different spoofed MAC addresses make the attack more effective? (c) Name one practical countermeasure that can be configured to limit the impact of this attack.
8. (a) What malicious configuration parameters can the attacker provide through a malicious DHCP server to enable a man-in-the-middle (MITM) attack? (b) Suppose an attacker wishes to perform both a DHCP starvation attack and a DHCP spoofing attack. In what sequence should these attacks be carried out, and why? (c) Mention one mechanism that can prevent clients from accepting offers from a malicious DHCP server.
9. How can an attacker infer the operating system of a target computer by analyzing its Transport layer behavior?
10. In a TCP SYN flooding attack, why does the attacker typically use different or spoofed source IP addresses rather than sending all SYN requests with the same source IP address?
11. In a TCP SYN flooding attack, what happens if the spoofed source IP address belongs to a legitimate machine that is currently active on the network?
12. Can we launch a SYN flooding attack from a computer without using the root privilege? Mention one countermeasure that can be configured to prevent SYN flooding attack.
13. An attacker on the same LAN as a client wishes to hijack an already established TCP session between that client and a remote server. The attacker can sniff some traffic from the client but cannot initially observe the server's replies to the client.
- (a) What critical piece of information must the attacker correctly determine or predict in order to inject forged packets that the server will accept as part of the existing session? (b) Why is it often necessary for the attacker to silence the legitimate client during the

hijack attempt? (c) Name one practical countermeasure that makes TCP session hijacking significantly harder to perform.

14. A user enters `https://www.mybank.com` into the browser, and the browser displays a login page that looks identical to the legitimate bank's website. However, due to manipulation of DNS resolution, the user is directed to a server controlled by an attacker.

(a) What type of attack could explain this situation? (b) Why might simply checking the URL fail to protect the user? (c) Explain how DNS resolution can be manipulated to enable this attack. (d) Explain how HTTPS/TLS certificates can help detect or prevent such an attack. (e) Why is pharming potentially more dangerous than a conventional phishing attack?

15. An organization uses a stateful firewall to allow internal hosts to access external web servers. An internal host `192.168.1.20:5000` sends a TCP SYN packet to `203.0.113.10:80`. The firewall later receives the following two incoming packets: Packet 1: `203.0.113.10:80 → 192.168.1.20:5000`, ACK = 1, and Packet 2: `198.51.100.5:80 → 192.168.1.20:5000`, ACK = 1. Which packet should the firewall allow and which should it block? Explain how the connection table helps the firewall make this decision, and why might a traditional packet filter incorrectly allow both packets?
16. You are tasked with designing a packet-filter firewall for a small research lab subnet `10.20.30.0/24`. The firewall uses a first-match-wins policy. The security requirements are:

- (i) The public web server is `10.20.30.10` and must be accessible from external networks using HTTPS (TCP port 443) only. HTTP (TCP port 80) must be blocked.
- (ii) SSH (TCP port 22) access to the web server is permitted only from the campus administration network `203.0.113.0/24`.
- (iii) Internal lab clients may send DNS queries to external DNS servers using UDP or TCP port 53.
- (iv) All other traffic must be denied.

Design the packet-filter firewall rules to enforce the above security policy. For each rule, specify the direction, source address, destination address, protocol, destination port, and action (Allow/Deny). Assume that the firewall processes rules from top to bottom and applies the action of the first matching rule.

17. In the OSI security architecture, security services, security mechanisms and security attacks form a conceptual triangle. Suppose a network administrator wants to guarantee that a message received by host B was indeed sent by host A and that the message content has not been altered in transit. Which combination of security service(s) and mechanism(s) is most appropriate?

- A. Confidentiality service + Encryption mechanism only
- B. Authentication + Data-integrity services; digital signature + hash-based MAC mechanisms
- C. Availability service + Traffic-padding mechanism
- D. Access-control service + Packet-filter firewall only

18. A campus network has a DHCP pool of 254 addresses. Under normal load 150 addresses are leased with an average lease time of 24 h. An attacker on the same L2 segment can generate 500 DHCP DISCOVER messages per minute, each carrying a unique forged MACaddress. Assume every request is granted and that no address is released until its lease expires.
- (a) How many minutes does the attacker need to exhaust the remaining free addresses?
 - (b) If the lease time is reduced to 1 hour while the attacker continues at the same rate, does the initial exhaustion time change? Briefly explain the long-term effect on the success of the starvation attack.
19. Consider a DHCP starvation attack in which the DHCP server resides in a different IP subnet and is reached via a relay agent. The attacker forges the client hardware address (chaddr) field inside the DHCP payload while the Ethernet source MAC of the frame is that of the relay agent (or of the attacker's own interface if on the same segment). Which of the following statements is/are correct?
- I. Simple MAC-address limiting on the access switch ports is sufficient to stop the attack.
 - II. The relay agent can mitigate the attack by tracking the number of outstanding requests that share the same chaddr value.
 - III. Because the outer Ethernet source MAC belongs to the relay, rate-limiting based solely on outer MAC is ineffective against a sophisticated attacker.
- A. I and II only
 - B. II and III only
 - C. I and III only
 - D. I, II and III
20. In a TCP three-way handshake the initial sequence number (ISN) is chosen randomly. An off-path attacker who cannot observe the handshake packets wishes to inject a forged RST segment into an established connection between client C and server S. Which of the following statements is true?
- A. Random ISNs make the attack impossible because the attacker must guess a 32-bit sequence number that lies inside the receiver's window.
 - B. Random ISNs only protect against connection hijacking; a RST can still be accepted if the attacker guesses any sequence number that is currently acceptable.
 - C. Because RST segments do not carry data, the sequence-number check is omitted and the attack always succeeds.

D. The attack can succeed only when the attacker also spoofs the correct acknowledgement number; random ISNs therefore provide complete protection.

21. An attacker controls an authoritative name server for the domain eve.com. The local recursive resolver of a victim uses sequential 16-bit transaction IDs and a fixed source port. The attacker first queries the victim's resolver for www.eve.com (so that the resolver contacts the attacker's name server and the attacker learns the current ID). Immediately afterwards the attacker floods the resolver with forged replies for www.bank.com that contain a malicious glue record pointing to the attacker's IP. What is the approximate probability that at least one forged reply is accepted by the resolver, assuming the attacker can send 28 replies before the legitimate answer arrives?
- A. $\approx 1/256$
 - B. $\approx 1 - (1 - 1/216)^{256} \approx 1/256$
 - C. $\approx 1 - (1 - 1/216)^{256} \approx 1/256$ (but the sequential-ID knowledge raises it to nearly 1)
 - D. Nearly 1, because the attacker already knows the next transaction ID that will be used for the bank.com query
22. In DNS amplification attacks an adversary spoofs the source IP of a small query so that a large response is directed at a victim. Suppose a DNS query of 60 bytes elicits a response of 3000 bytes (amplification factor 50). An attacker with a 100 Mbps uplink can generate 200 000 queries per second. What is the maximum traffic volume (in Gbps) that can be directed at the victim, assuming all queries are answered?
- A. 0.1 Gbps
 - B. 5 Gbps
 - C. 30 Gbps
 - D. 50 Gbps
23. A traditional (stateless) packet-filter firewall is configured with the following ordered ACL for an organization whose internal addresses are 222.22.0.0/16:
1. allow TCP 222.22/16 $\rightarrow$ outside, src-port >1023, dst-port 80, any flags
 2. allow TCP outside $\rightarrow$ 222.22/16, src-port 80, dst-port >1023, ACK flag set
 3. allow UDP 222.22/16 $\rightarrow$ outside, src-port >1023, dst-port 53
 4. allow UDP outside $\rightarrow$ 222.22/16, src-port 53, dst-port >1023
 5. deny all
- Which of the following traffic patterns is/are permitted?
- I. An internal host initiates an HTTP connection to an external web server and receives the responses.
 - II. An external host initiates a TCP connection to an internal host on port 80.
 - III. An internal host sends a DNS query and receives the reply.
 - IV. An external host sends unsolicited UDP packets to an internal high port claiming to be DNS replies.

- A. I and III only
- B. I, III and IV only
- C. I and II only
- D. All of I–IV

24. Compare traditional packet filters, stateful packet filters and application-level gateways with respect to the following three properties:

P1: Ability to enforce that a TCP SYN packet is accepted only if it is the first packet of a legitimate three-way handshake initiated from the inside.

P2: Ability to inspect the payload of an HTTP request and block requests containing SQL-injection patterns.

P3: Computational cost per packet under heavy load. Which ordering of the three firewall types (from lowest to highest cost, and from weakest to strongest capability) is correct?

- A. Traditional < Stateful < Application-gateway (both for cost and for capability on P1/P2)
- B. Traditional < Application-gateway < Stateful
- C. Stateful < Traditional < Application-gateway
- D. Application-gateway < Stateful < Traditional

25. An organization wishes to allow internal hosts to open TCP connections to any external host, but to forbid external hosts from opening TCP connections to any internal host (except a designated public web server at 130.207.244.203:80). A traditional packet filter is to be used. Which of the following rule sets correctly realises the policy? (Rules are examined in order; the first matching rule is applied.)

A. allow TCP any → 130.207.244.203:80 SYN; drop TCP any → internal SYN; allow TCP any ↔ any

B. drop all inbound TCP packets with ACK=0 except those destined to 130.207.244.203:80; allow all other TCP

C. allow all outbound TCP; drop all inbound TCP

D. Both A and B are equivalent and correct; C is incorrect because it also blocks return traffic of legitimate outbound connections